

ENCUESTA INTEGRAL DE CIBERSEGURIDAD EN SISTEMAS DE IA: ESPAÑA 2026

Modelo Detallado de Encuesta con Módulos y Escalas de Madurez

Versión: 1.0 Integral

Aplicabilidad: Organizaciones públicas y privadas España (sector crítico, PYME, grandes empresas)

Duración estimada: 35-45 minutos

Idioma: Español (variante peninsular con inflexiones terminológicas reconocidas)

INTRODUCCIÓN Y CONTEXTO DE LA ENCUESTA

Estimado/a responsable de ciberseguridad y experto en resiliencia digital:

Esta encuesta ha sido diseñada como instrumento de auto-evaluación riguroso para analizar la postura actual de ciberseguridad de su organización, **especialmente en contexto de sistemas de Inteligencia Artificial, amenazas emergentes 2024-2025 y marcos regulatorios europeos** (AI Act EU 2024/1689, NIS2, RGPD, AIDA español).

El propósito dual de esta investigación es:

1. Diagnóstico estratégico de vulnerabilidades, brechas de madurez y oportunidades de fortalecimiento
2. Benchmarking comparativo sectorial: validación posición relativa frente a pares, identificación estándares excellence

Garantías de confidencialidad: Todos los datos serán anonimizados, agregados a nivel sectorial, y presentados únicamente a stakeholders autorizados bajo acuerdos NDA.

PERFIL ORGANIZACIONAL (SECCIÓN I)

Preguntas de contexto para segmentación y análisis comparativo posterior

1.1 Identificación Básica de la Organización

Pregunta: ¿Cuál es el tamaño de su organización?

- ☐ Microempresa (1-9 empleados)
- ☐ Pequeña empresa (10-49 empleados)
- ☐ Mediana empresa (50-249 empleados)
- ☐ Gran empresa (250-999 empleados)
- ☐ Muy gran empresa (1000+ empleados)
- ☐ Administración Pública (local, regional, estatal)
- ☐ Organización sin ánimo de lucro / Academia

1.2 Sector de Actividad Económica

Pregunta: ¿A qué sector primario pertenece su organización?

- ☐ Tecnología / Software / Telecomunicaciones
- ☐ Servicios Financieros (banca, seguros, fondos)
- ☐ Manufactura / Industria
- ☐ Energía / Infraestructuras Críticas
- ☐ Sanidad / Farmacéutica
- ☐ Defensa / Seguridad Pública
- ☐ Educación / Investigación
- ☐ Administración Pública
- ☐ Comercio / E-commerce
- ☐ Logística / Transporte
- ☐ Otra (especifique): ____

1.3 Clasificación Datos Sensibles

Pregunta: ¿Qué tipos de datos sensibles procesa su organización? *(Marque todos los aplicables)*

- ☐ Información Controlada No Clasificada (CUI) / datos defensa
- ☐ Información identificable personalmente (PII/datos personales RGPD)
- ☐ Secretos comerciales / propiedad intelectual
- ☐ Datos financieros / contables
- ☐ Información sanitaria / médica
- ☐ Datos biométricos / identificación
- ☐ Información ubicación / geolocalización
- ☐ Datos comunicaciones personales (email, chat)
- ☐ No procesa datos especialmente sensibles

1.4 Ubicación Principal

Pregunta: ¿Cuál es su ubicación geográfica principal de operaciones?

- ☐ España (sede España)
- ☐ UE (incluida España como filial)
- ☐ Resto del mundo (especifique): ____
- ☐ Operaciones multinacionales (multisedes)

1.5 Experiencia Ciberseguridad Organizacional

Pregunta: ¿Cuántos años llevan invirtiendo formalmente en ciberseguridad?

- ☐ < 2 años (iniciativa reciente)
- ☐ 2-5 años
- ☐ 5-10 años
- ☐ 10+ años (programa maduro)

GOBERNANZA Y ESTRATEGIA (SECCIÓN II)

Evaluación estructura gobierno, políticas, liderazgo, presupuesto en ciberseguridad

2.1 Estructura de Gobernanza

Pregunta: ¿Existe una estructura formal de gobernanza de ciberseguridad en su organización?

Escala de Madurez (5 puntos):

- ☐ (1) No existe: No hay rol, comité, ni proceso formalizado
- ☐ (2) Iniciado: Existen roles aislados (CISO ad-hoc, sin comité)
- ☐ (3) Parcialmente implementado: CISO designado, comité riesgos informático con <50% cobertura
- ☐ (4) Implementado: CISO dedicado, comité riesgos establecido, reuniones periódicas
- ☐ (5) Optimizado: CISO C-level, comité riesgos multidisciplinario, board oversight, métricas continuas

Pregunta complementaria: Si existe CISO/responsable, ¿reporta directamente a?

- ☐ C-suite (CEO, CFO, COO)
- ☐ CTO / VP Tecnología
- ☐ Director Riesgos
- ☐ Director Operaciones
- ☐ Otro: ____

2.2 Política de Ciberseguridad Documentada

Pregunta: ¿Existe una política de ciberseguridad integral y documentada?

Escala de Madurez:

- ☐ (1) No existe: Sin documentación formal
- ☐ (2) Iniciado: Documento borrador o parcial
- ☐ (3) Parcial: Política existe pero cobertura <75% de áreas críticas
- ☐ (4) Implementada: Política completa, actualizada anualmente, comunicada
- ☐ (5) Optimizada: Política integral, revisada/actualizada semestral o trimestral, con métricas de cumplimiento

Pregunta complementaria: ¿Se revisa y actualiza esta política regularmente?

- ☐ Ad-hoc (sin calendario)
- ☐ Anualmente
- ☐ Semestralmente
- ☐ Trimestralmente
- ☐ Continuamente (revisión permanente)

2.3 Política de IA y Gobernanza Específica

Pregunta: ¿Existe una política específica de Inteligencia Artificial, Machine Learning y sistemas autónomos?

Escala de Madurez:

- ☐ (1) No existe: Sin consideración formal de IA
- ☐ (2) Iniciado: Conciencia de riesgos IA; documento en desarrollo
- ☐ (3) Parcial: Política IA existe pero no cubre agentes autónomos, Shadow AI, cadena suministro modelos
- ☐ (4) Implementada: Política IA completa, incluye governance modelos, cadena suministro, capacitación
- ☐ (5) Optimizada: Política IA integral, alineada AESIA/AI Act EU 2024, con auditorías continuas MITRE ATLAS

Pregunta complementaria: ¿Aborda esta política los siguientes temas? *(Marque todos los aplicables)*

- ☐ Selección y vetting de modelos/datasets
- ☐ Shadow AI (uso no autorizado herramientas IA)
- ☐ Seguridad de datos training (poisoning, adversarial)
- ☐ Prompt injection y defensa LLM
- ☐ Transparencia decisiones automatizadas
- ☐ Privacidad datos training (RGPD)
- ☐ Governance agentes autónomos
- ☐ Ninguno de los anteriores

2.4 Alineación con Marcos Regulatorios

Pregunta: ¿Ha evaluado su organización la conformidad con siguientes marcos? *(Marque todos; para cada uno, indique estado)*

Marco	No evaluado	En evaluación	Parcialmente conforme	Conforme	Certificado
AI Act (EU 2024/1689)	☐	☐	☐	☐	☐
NIS2 (Directiva 2022/2555)	☐	☐	☐	☐	☐
RGPD (Datos personales)	☐	☐	☐	☐	☐
AIDA (España)	☐	☐	☐	☐	☐
ISO 27001	☐	☐	☐	☐	☐
PCI-DSS (si maneja datos pago)	☐	☐	☐	☐	☐
HIPAA (si datos sanitarios)	☐	☐	☐	☐	☐

2.5 Presupuesto Anual Ciberseguridad

Pregunta: ¿Cuál es el presupuesto anual aproximado destinado a ciberseguridad (infraestructura, personal, servicios)?

- ☐ < 10.000 €
- ☐ 10.000 - 50.000 €
- ☐ 50.001 - 250.000 €
- ☐ 250.001 - 1.000.000 €
- ☐ 1.000.001 - 5.000.000 €
- ☐ > 5.000.000 €
- ☐ No cuantificado / desconocido

Pregunta complementaria: ¿Cómo ha evolucionado este presupuesto en los últimos 3 años?

- ☐ Reducido (< 10%)
- ☐ Mantenido ($\pm 10\%$)
- ☐ Incrementado (10-30%)
- ☐ Muy incrementado (> 30%)
- ☐ Desconocido

2.6 Planificación Continuidad Negocio

Pregunta: ¿Existe un Plan de Continuidad de Negocio (BCP) documentado y actualizado?

Escala de Madurez:

- ☐ (1) No existe: Sin documentación BCP
- ☐ (2) Iniciado: Documento borrador; identificación crítico incompleta
- ☐ (3) Parcial: BCP existe pero cobertura < 50% operaciones o no actualizado >12 meses
- ☐ (4) Implementado: BCP completo, RTO/RPO definidos, actualizado anualmente
- ☐ (5) Optimizado: BCP integral, probado regularmente ($\geq$ anual), con métricas SLA monitoreo continuo

Pregunta complementaria: ¿Se realizan pruebas/simulacros BCP?

- ☐ Nunca
- ☐ Ad-hoc (sin calendario)
- ☐ Anualmente
- ☐ Semestralmente
- ☐ Trimestralmente o más frecuente

GESTIÓN DE ACTIVOS (SECCIÓN III)

Inventario, clasificación, mapeo dependencias y Shadow IT

3.1 Inventario Sistemas TI

Pregunta: ¿Existe un inventario centralizado, actualizado de todos los activos TI (hardware, software, aplicaciones)?

Escala de Madurez:

- ☐ (1) No existe: Sin inventario formal; conocimiento ad-hoc
- ☐ (2) Iniciado: Inventario parcial; cobertura <40%
- ☐ (3) Parcial: Inventario existe; cobertura 40-80%; actualización anual
- ☐ (4) Implementado: Inventario centralizado, cobertura >80%, actualización semestral
- ☐ (5) Optimizado: Inventario automatizado (CMDB/ITSM), cobertura 100%, actualización en tiempo real

Pregunta complementaria: ¿Se utiliza una herramienta CMDB (Configuration Management Database) o similar?

- ☐ No
- ☐ Sí, con cobertura < 50%
- ☐ Sí, con cobertura 50-80%
- ☐ Sí, con cobertura > 80%

3.2 Clasificación de Datos

Pregunta: ¿Existe un esquema de clasificación de datos documentado (e.g., público, interno, confidencial, restringido)?

Escala de Madurez:

- ☐ (1) No existe: Sin clasificación formal
- ☐ (2) Iniciado: Esquema definido pero aplicación <25%
- ☐ (3) Parcial: Esquema aplicado a 25-75% datos; training limitado
- ☐ (4) Implementado: Esquema aplicado >75% datos; auditoría regular; training completado
- ☐ (5) Optimizado: Clasificación automatizada (tagging DLP), 100% cobertura, revisión continua basada en riesgos

Pregunta complementaria: ¿Se aplica tratamiento diferenciado (encriptación, acceso, backup) según clasificación?

- ☐ No, acceso uniforme
- ☐ Parcialmente (solo niveles extremos)
- ☐ Sí, para todos los niveles

3.3 Identificación Sistemas IA/ML

Pregunta: ¿Ha identificado y catalogado todos los sistemas IA/ML en operación en su organización?

Escala de Madurez:

- ☐ (1) No existe: Sin inventario IA; desconocimiento posible Shadow AI
- ☐ (2) Iniciado: Lista parcial identificada (>50% probable); planes evaluación
- ☐ (3) Parcial: Catálogo IA existe; cobertura ~75%; algunos sistemas aún desconocidos
- ☐ (4) Implementado: Inventario IA completo (>90%); documentado arquitectura, provenance datos
- ☐ (5) Optimizado: Catálogo IA en tiempo real; integrado a governance, con análisis riesgo ATLAS continuo

Pregunta complementaria: ¿Qué tipos de sistemas IA operan? *(Marque todos los aplicables)*

- ☐ LLMs/chatbots generativos (ChatGPT, Copilot, modelos custom)
- ☐ Sistemas visión computacional (OCR, detección objetos)
- ☐ Modelos predictivos (forecasting, scoring crediticio)
- ☐ Sistemas autónomos (agentes, RPA, toma decisiones)
- ☐ Sistemas recomendación/personalización
- ☐ Detectores anomalías (outlier detection)
- ☐ Ninguno / Desconocido

3.4 Dependencias Proveedores y Cadena Suministro

Pregunta: ¿Ha mapeado sus dependencias críticas con proveedores TI, cloud, IA?

Escala de Madurez:

- ☐ (1) No existe: Sin mapeo formalizado
- ☐ (2) Iniciado: Mapeo parcial; solo proveedores principales identificados
- ☐ (3) Parcial: Mapeo >50% proveedores; documentación incompleta
- ☐ (4) Implementado: Mapeo >80% proveedores; documentado dependencias críticas; monitoreo riesgos
- ☐ (5) Optimizado: Supply chain graph completo; análisis cascada de riesgos; monitoreo continuo SLA/SLO

Pregunta complementaria: ¿Cuántos proveedores terceros considera críticos?

- ☐ < 5
- ☐ 5-10
- ☐ 11-25
- ☐ 26-50
- ☐ > 50
- ☐ Desconocido

3.5 Shadow IT Governance

Pregunta: ¿Ha implementado controles para identificar y gobernar "Shadow IT" (herramientas, aplicaciones, IA no autorizadas)?

Escala de Madurez:

- ☐ (1) No existe: Sin intentos detección Shadow IT
- ☐ (2) Iniciado: Conciencia del riesgo; auditorías manuales ocasionales
- ☐ (3) Parcial: Herramientas detección (CASB, discovery) implementadas parcialmente
- ☐ (4) Implementado: Soluciones discovery integradas; auditorías regulares; políticas comunicadas
- ☐ (5) Optimizado: Cloud Access Security Broker (CASB) + análisis comportamiento usuarios; governance automática, integrada gobernanza TI

Pregunta complementaria: ¿Se conoce el porcentaje estimado de Shadow IT en su organización?

- ☐ No, nunca evaluado
- ☐ Sí, <5% del uso TI
- ☐ Sí, 5-15%
- ☐ Sí, 16-30%
- ☐ Sí, >30%

GESTIÓN DE VULNERABILIDADES Y ANÁLISIS DE RIESGO (SECCIÓN IV)

Escaneo, evaluación, clasificación, pentesting, MITRE ATLAS mapping

4.1 Programa Escaneo Vulnerabilidades

Pregunta: ¿Realiza escaneos automatizados de vulnerabilidades en su infraestructura?

Escala de Madurez:

- ☐ (1) No existe: Sin escaneo formalizado
- ☐ (2) Iniciado: Escaneos ad-hoc; herramientas básicas; cobertura <40%
- ☐ (3) Parcial: Escaneo trimestral/semestral; cobertura 40-80%; herramientas estándar (Nessus, Qualys)
- ☐ (4) Implementado: Escaneos mensuales con cobertura >80%; automatización de reportes; workflow remediación
- ☐ (5) Optimizado: Escaneo continuo con scoring riesgo dinámico; integración SIEM; priorización automática patch

Pregunta complementaria: ¿Qué herramientas utiliza? (*Marque todas las aplicables*)

- ☐ Nessus / Tenable
- ☐ Qualys VMDR
- ☐ OpenVAS / Greenbone
- ☐ Rapid7 InsightVM
- ☐ Acunetix (web apps)
- ☐ Herramientas internas/custom
- ☐ Ninguna formalizada

4.2 Gestión de Vulnerabilidades: Ciclo Remediación

Pregunta: ¿Cuál es el tiempo promedio de remediación para vulnerabilidades críticas identificadas?

- ☐ > 90 días (no gestiona activamente)
- ☐ 30-90 días
- ☐ 14-30 días
- ☐ 7-14 días
- ☐ < 7 días
- ☐ Desconocido / sin tracking

Pregunta complementaria: ¿Existe una política de SLA para parches según criticidad?

- ☐ No
- ☐ Sí, pero no documentada
- ☐ Sí, documentada pero parcialmente seguida
- ☐ Sí, documentada y monitoreada continuamente

4.3 Gestión Zero-Day

Pregunta: ¿Ha establecido un proceso para identificar y responder a vulnerabilidades zero-day?

Escala de Madurez:

- ☐ (1) No existe: Sin proceso; descubre zero-days post-exploración
- ☐ (2) Iniciado: Monitoreo fuentes seguridad (no sistemático)
- ☐ (3) Parcial: Suscripción alertas; identificación <48h; capacidad remediación limitada
- ☐ (4) Implementado: Suscripción múltiples inteligencias amenazas; proceso respuesta activado <24h; workarounds documentados
- ☐ (5) Optimizado: Inteligencia amenazas integrada SIEM; simulación escenarios zero-day; redundancia aplicada

4.4 Programa Evaluación Riesgos Formal

Pregunta: ¿Realiza evaluaciones de riesgo (Risk Assessment) de forma estructurada?

Escala de Madurez:

- ☐ (1) No existe: Sin evaluaciones formales
- ☐ (2) Iniciado: Evaluaciones ad-hoc; metodología inconsistente
- ☐ (3) Parcial: Evaluaciones anuales; metodología documentada; cobertura >50% sistemas
- ☐ (4) Implementado: Evaluaciones anuales + ad-hoc cambios grandes; NIST RMF o equivalente; cobertura >80%
- ☐ (5) Optimizado: Evaluaciones continuas con scoring dinámico; integración a gobernanza decisiones inversión IT

Pregunta complementaria: ¿Qué metodología utiliza para evaluación de riesgos?

- ☐ No formalizada / Ad-hoc
- ☐ NIST RMF (Risk Management Framework)
- ☐ ISO 27001 / ISO 31000
- ☐ CMMC (Cybersecurity Maturity Model)
- ☐ Marco interno custom
- ☐ Otra: ____

4.5 Pruebas de Penetración (Pentesting)

Pregunta: ¿Realiza pruebas de penetración (pentesting) de su infraestructura?

Escala de Madurez:

- ☐ (1) No existe: Nunca ha realizado pentesting
- ☐ (2) Iniciado: Pentesting ad-hoc (1 vez en última vigencia); alcance limitado
- ☐ (3) Parcial: Pentesting anual; alcance ~70% (apps, redes); cobertura incompleta
- ☐ (4) Implementado: Pentesting anual + trimestral focalizados; alcance >85%; remediación documentada
- ☐ (5) Optimizado: Pentesting continuo + red teaming; cobertura 100% incluye IA systems; integración SIEM; métricas tracked

Pregunta complementaria: ¿Con qué frecuencia realiza pentesting?

- ☐ Nunca
- ☐ Ad-hoc (no programado)
- ☐ Anualmente
- ☐ Semestralmente
- ☐ Trimestralmente
- ☐ Mensualmente

4.6 Cobertura Pentesting: Áreas Evaluadas

Pregunta: ¿Qué áreas cubre su programa de pentesting? (*Marque todos los aplicables*)

- ☐ Redes externas / perimetro
- ☐ Aplicaciones web
- ☐ Aplicaciones internas
- ☐ Cloud (IaaS, SaaS)
- ☐ Infraestructura OT (operational technology)
- ☐ IoT / dispositivos perimetrales
- ☐ Cadena suministro (proveedores API)
- ☐ Sistemas IA/LLM específicamente (prompt injection, model extraction, poisoning)
- ☐ Ninguna / No documentado

4.7 Red Teaming / Adversarial Testing

Pregunta: ¿Realiza ejercicios de Red Teaming o testing adversarial simulando ataques complejos?

Escala de Madurez:

- ☐ (1) No existe: Sin red teaming
- ☐ (2) Iniciado: Ocasional; scope muy limitado
- ☐ (3) Parcial: Red teaming anual; cobertura <50% cadena ataque
- ☐ (4) Implementado: Red teaming semestral; cobertura 50-80%; simulación multi-fase
- ☐ (5) Optimizado: Red teaming continuo; cobertura 100% fases ataque (reconocimiento—impacto); integra MITRE ATLAS escenarios

4.8 MITRE ATLAS Mapping

Pregunta: ¿Ha mapeado su infraestructura contra técnicas de ataque MITRE ATLAS (amenazas específicas IA)?

Escala de Madurez:

- ☐ (1) No existe: Sin conocimiento o consideración ATLAS
- ☐ (2) Iniciado: Conciencia ATLAS; evaluación manual incompleta
- ☐ (3) Parcial: Mapeo ~50% sistemas IA contra ATLAS; documentación incompleta
- ☐ (4) Implementado: Mapeo >80% sistemas IA; identificadas 10-15 técnicas ATLAS críticas; plan remediación
- ☐ (5) Optimizado: Mapeo completo ATLAS; 15 tácticas / 66 técnicas evaluadas; defensa específica per táctica; testing continuo

Pregunta complementaria: ¿Qué amenazas ATLAS le preocupan más? (Marque 3 máximo como "muy críticas")

- ☐ AML.T0051 - Prompt Injection
- ☐ AML.T0020 - Data Poisoning
- ☐ AML.T0044 - Model Extraction
- ☐ AML.T0054 - LLM Jailbreak
- ☐ AML.T0056 - LLM Meta Prompt Extraction
- ☐ AML.T0058 - Publish Poisoned Models
- ☐ AML.T0065 - AI Agent Context Poisoning
- ☐ AML.T0066 - Memory Manipulation (Agentic)
- ☐ Todas por igual
- ☐ No ha evaluado

SEGURIDAD DE DATOS Y PROTECCIÓN (SECCIÓN V)

Encryptación, backup, RGPD, DLP

5.1 Encryptación Datos en Tránsito

Pregunta: ¿Están encriptados los datos en tránsito (transmisión entre sistemas)?

Escala de Madurez:

- ☐ (1) No: Transmisión en claro o sin control
- ☐ (2) Iniciado: Encriptación en tránsito solo en conexiones externas (internet)
- ☐ (3) Parcial: TLS/SSL implementado >50% conexiones; protocolos seguros parcialmente
- ☐ (4) Implementado: TLS 1.2+ en >90% conexiones; protocolos seguros (HTTPS, SSH, VPN)
- ☐ (5) Optimizado: TLS 1.3+ en 100% conexiones; perfect forward secrecy; rotación certificados automatizada

Pregunta complementaria: ¿Se utiliza encriptación en conexiones internas (LANs)?

- ☐ No
- ☐ Parcialmente (solo conexiones críticas)
- ☐ Sí, todas las conexiones

5.2 Encriptación Datos en Reposo

Pregunta: ¿Están encriptados los datos almacenados (bases datos, file systems, backups)?

Escala de Madurez:

- ☐ (1) No: Datos en claro
- ☐ (2) Iniciado: Encriptación solo nivel disco/volumen; no granular
- ☐ (3) Parcial: Encriptación >50% datos sensibles; algoritmo AES pero gestión clave manual
- ☐ (4) Implementado: Encriptación AES-256 >90% datos sensibles; gestión clave centralizada
- ☐ (5) Optimizado: Encriptación AES-256+ 100% datos clasificados; key management automatizado; HSM integrado; rotación clave periódica

Pregunta complementaria: ¿Existe una solución centralizada de gestión de claves criptográficas?

- ☐ No
- ☐ Sí, manual (archivos almacenados)
- ☐ Sí, semi-automatizada
- ☐ Sí, KMS integrado (AWS KMS, Azure Key Vault, HashiCorp Vault)

5.3 Gestión de Claves Criptográficas

Pregunta: ¿Existe un programa formal de gestión de ciclo de vida de claves?

Escala de Madurez:

- ☐ (1) No existe: Claves sin gestión formal
- ☐ (2) Iniciado: Generación, almacenamiento pero sin rotación sistemática
- ☐ (3) Parcial: Rotación de claves implementada pero no completamente automática
- ☐ (4) Implementado: Rotación automática según SLA; auditoría acceso claves; separación obligaciones
- ☐ (5) Optimizado: HSM/Key Management Service; rotación automática por algoritmo/tiempo; auditoría continua; disaster recovery claves

Pregunta complementaria: ¿Se aplica el principio de "Separation of Duties" en gestión de claves?

- ☐ No
- ☐ Parcialmente
- ☐ Sí, completamente implementado

5.4 Backup y Recuperación

Pregunta: ¿Existe un programa formal de backup y recuperación de datos?

Escala de Madurez:

- ☐ (1) No existe: Sin backup formalizado
- ☐ (2) Iniciado: Backups ad-hoc; sin RTO/RPO definidos
- ☐ (3) Parcial: Backups diarios; RTO/RPO definido pero no siempre alcanzado; pruebas infrecuentes
- ☐ (4) Implementado: Backups automáticos 24h; RTO <4h, RPO <1h para crítico; pruebas mensuales
- ☐ (5) Optimizado: Backup continuo/incremental; RTO <1h, RPO <15min crítico; pruebas semanales; disaster recovery plan activo

Pregunta complementaria: ¿Cuál es el RTO (Recovery Time Objective) y RPO (Recovery Point Objective) para sistemas críticos?

- ☐ No definido
- ☐ RTO > 24h, RPO > 8h
- ☐ RTO 4-24h, RPO 1-8h
- ☐ RTO 1-4h, RPO <1h
- ☐ RTO <1h, RPO <15min

5.5 Data Loss Prevention (DLP)

Pregunta: ¿Ha implementado soluciones de Data Loss Prevention (DLP)?

Escala de Madurez:

- ☐ (1) No existe: Sin controles DLP
- ☐ (2) Iniciado: DLP en endpoints solamente; reglas básicas
- ☐ (3) Parcial: DLP endpoints + email; cobertura <50% flujos datos
- ☐ (4) Implementado: DLP endpoints, email, cloud; cobertura >75%; reglas sofisticadas; auditoría eventos
- ☐ (5) Optimizado: DLP integrado en todos canales; AI/ML para detección anomalías; integrado SIEM; bloqueo/cuarentena automático

Pregunta complementaria: ¿Qué canales monitorea DLP? (Marque todos los aplicables)

- ☐ Email
- ☐ Endpoint (copiar, USB, print)
- ☐ Cloud (Box, SharePoint, Google Drive)
- ☐ Aplicaciones web (custom)
- ☐ APIs/integraciones terceros
- ☐ Ninguno formalizado

5.6 Cumplimiento RGPD

Pregunta: ¿Ha implementado medidas específicas para cumplir RGPD (derecho olvido, portabilidad, consent)?

Escala de Madurez:

- ☐ (1) No existe: Sin consideración RGPD
- ☐ (2) Iniciado: Conciencia; evaluación DPIA iniciada
- ☐ (3) Parcial: EIPD completadas; medidas parcialmente implementadas; derecho olvido manual
- ☐ (4) Implementado: EIPD completas; derecho olvido y portabilidad automatizados; auditoría anual
- ☐ (5) Optimizado: Privacy by design; automatización completa RGPD; integración procesamiento; auditoría continua; DPA en lugar

Pregunta complementaria: ¿Existe Data Protection Officer (DPO) designado?

- ☐ No
- ☐ Sí, pero con cobertura parcial
- ☐ Sí, dedicado (interno)
- ☐ Sí, dedicado (externo/consultor)

DETECCIÓN Y MONITOREO: SIEM (SECCIÓN VI)

Gestión información eventos seguridad, correlación, análisis

6.1 Existencia Solución SIEM

Pregunta: ¿Tiene implementada una solución SIEM (Security Information and Event Management)?

Escala de Madurez:

- ☐ (1) No existe: Sin SIEM; logs distribuidos
- ☐ (2) Iniciado: SIEM piloto; pocas fuentes integradas (<5)
- ☐ (3) Parcial: SIEM activo; 5-15 fuentes de logs; algunas alertas configuradas
- ☐ (4) Implementado: SIEM completo; 15-30 fuentes; alertas sofisticadas; reportaría regular
- ☐ (5) Optimizado: SIEM empresarial; 30+ fuentes; UEBA integrado; AI para detección anomalías; SOAR integrado

Pregunta complementaria: ¿Qué solución SIEM utiliza?

- ☐ Splunk
- ☐ Microsoft Sentinel
- ☐ Elastic (ELK)
- ☐ IBM QRadar
- ☐ ArcSight
- ☐ Solución custom/open-source
- ☐ No SIEM implementado

6.2 Fuentes de Datos Integradas

Pregunta: ¿Cuántas y qué tipos de fuentes de datos están integradas en su SIEM?

Escala de Madurez:

- ☐ (1) < 5 fuentes: Cobertura mínima (solo algunos logs)
- ☐ (2) 5-15 fuentes: Cobertura básica (redes, servidores, algunos endpoints)
- ☐ (3) 15-30 fuentes: Cobertura media (infraestructura IT + cloud + algunos aplicativos)
- ☐ (4) 30-50 fuentes: Cobertura alta (IT + cloud + aplicativos + identidad + endpoints)
- ☐ (5) 50+ fuentes: Cobertura completa (todos sistemas + threat intel + DNS/flujo)

Pregunta complementaria: ¿Qué tipos de fuentes está conectado? (*Marque todos*)

- ☐ Firewalls / Proxies
- ☐ Servidores (Windows, Linux)
- ☐ Bases de datos
- ☐ Aplicaciones custom
- ☐ Cloud (AWS, Azure, GCP)
- ☐ Identidad/Directorio (AD, LDAP, SSO)
- ☐ Endpoints (EDR, antivirus)
- ☐ DNS / Flujos de red
- ☐ IoT / OT
- ☐ Inteligencia de amenazas externas

6.3 Tiempo Medio Detección (MTTD)

Pregunta: ¿Cuál es el tiempo medio para detectar un incidente de seguridad desde que ocurre?

- ☐ > 7 días (sin detección proactiva)
- ☐ 2-7 días
- ☐ 8-24 horas
- ☐ 2-8 horas
- ☐ < 2 horas
- ☐ Desconocido / sin tracking

Pregunta complementaria: ¿Ha mejorado el MTTD en los últimos 2 años?

- ☐ Peor (más lento)
- ☐ Igual
- ☐ Mejorado (reducido <20%)
- ☐ Significativamente mejorado (reducido 20-50%)
- ☐ Muy mejorado (reducido >50%)

6.4 Configuración de Alertas

Pregunta: ¿Qué porcentaje de alertas SIEM son investigadas vs. automáticamente filtradas?

- ☐ Bajo (<10% investigadas): Muy alto ruido
- ☐ Medio (10-30% investigadas): Mucho ruido
- ☐ Moderado (30-60% investigadas): Balance
- ☐ Alto (60-80% investigadas): Alertas relevantes
- ☐ Muy alto (>80% investigadas): Señal limpia; pocos falsos positivos

Pregunta complementaria: ¿Se utiliza machine learning para reducir falsos positivos?

- ☐ No
- ☐ Sí, basic (reglas estáticas)
- ☐ Sí, ML simple (anomaly detection básico)
- ☐ Sí, ML avanzado (behavioral analysis, UEBA)

6.5 Análisis Comportamiento Usuarios y Entidades (UEBA)

Pregunta: ¿Existe capacidad de análisis de comportamiento usuarios/entidades (UEBA)?

Escala de Madurez:

- ☐ (1) No existe: Sin análisis comportamiento
- ☐ (2) Iniciado: Herramientas UEBA en piloto; alcance limitado
- ☐ (3) Parcial: UEBA implementado; cobertura ~50% usuarios; baselines comportamiento
- ☐ (4) Implementado: UEBA completo; cobertura >80% usuarios; detección anomalías en tiempo real
- ☐ (5) Optimizado: UEBA avanzado; ML continuo; integración riesgos insider; automatización respuesta

6.6 Inteligencia de Amenazas Integrada

Pregunta: ¿Está integrada la inteligencia de amenazas externas en SIEM?

Escala de Madurez:

- ☐ (1) No: Sin feeds inteligencia
- ☐ (2) Iniciado: Una o dos fuentes threat intel básicas
- ☐ (3) Parcial: 2-3 feeds integrados; datos IOCs (indicadores)
- ☐ (4) Implementado: 3-5 feeds profesionales; análisis contextual; SOAR integrado
- ☐ (5) Optimizado: 5+ feeds premium + inteligencia interna; análisis ATT&CK integración supply chain intel

Pregunta complementaria: ¿Suscribe a servicios threat intelligence premium?

- ☐ No
- ☐ Sí, 1 servicio
- ☐ Sí, 2 servicios
- ☐ Sí, 3+ servicios

RESPUESTA A INCIDENTES (SECCIÓN VII)

Plan, equipo, métricas, simulacros, post-mortem

7.1 Plan Respuesta a Incidentes

Pregunta: ¿Existe un plan de respuesta a incidentes (IRP - Incident Response Plan) documentado?

Escala de Madurez:

- ☐ (1) No existe: Sin documentación formal
- ☐ (2) Iniciado: Documento borrador; roles incompletos
- ☐ (3) Parcial: Plan existe; cobertura <75% escenarios; roles definidos; comunicado a <50% personal
- ☐ (4) Implementado: Plan completo; 75%+ escenarios; roles definidos; training anual; actualizado
- ☐ (5) Optimizado: Plan integral; 100% escenarios; automatización SOAR; métricas tracked; revisión continua

Pregunta complementaria: ¿Se ha comunicado el plan a todo el personal relevante?

- ☐ No o muy parcialmente (<25%)
- ☐ Parcialmente (25-50%)
- ☐ Mayormente (50-75%)
- ☐ Completamente (>75%)

7.2 Equipo Respuesta Incidentes (CSIRT)

Pregunta: ¿Existe un equipo dedicado de respuesta a incidentes (CSIRT - Computer Security Incident Response Team)?

Escala de Madurez:

- ☐ (1) No existe: Sin equipo dedicado; ad-hoc cuando necesario
- ☐ (2) Iniciado: Equipo ad-hoc; <3 personas; sin training formalizado
- ☐ (3) Parcial: Equipo designado 3-5 personas; training básico; disponibilidad parcial
- ☐ (4) Implementado: CSIRT de 5-10 personas; training regular; on-call 24/7; SOPs documentadas
- ☐ (5) Optimizado: CSIRT especializado >10 personas; training continuo; 24/7/365; integrado SOC

7.3 Tiempo Medio Contención (MTTC) y Resolución (MTTR)

Pregunta: ¿Cuáles son los tiempos medios de contención (MTTC) y resolución (MTTR) de incidentes?

Tiempo	Incidentes Críticos	Incidentes Altos	Incidentes Medios
MTTC (Contención)	☐ >24h ☐ 6-24h ☐ <6h	☐ >24h ☐ 6-24h ☐ <6h	☐ >48h ☐ 24-48h ☐ <24h
MTTR (Resolución completa)	☐ >7 días ☐ 3-7 ☐ <3 días	☐ >14 días ☐ 7-14 ☐ <7 días	☐ >30 días ☐ 7-30 ☐ <7 días

7.4 Simulacros y Ejercicios Respuesta

Pregunta: ¿Se realizan simulacros de respuesta a incidentes?

Escala de Madurez:

- ☐ (1) No existe: Sin simulacros
- ☐ (2) Iniciado: Tabletop exercise ocasional
- ☐ (3) Parcial: Simulacro anual; algunos equipos participan
- ☐ (4) Implementado: Simulacro semestral; participación >75%; cobertura múltiples escenarios
- ☐ (5) Optimizado: Simulacros trimestrales; todos equipos; escenarios realistas + inyección sorpresas; métricas evaluadas

Pregunta complementaria: ¿Qué tipos de simulacros realiza?

- ☐ Tabletop (discusión teórica)
- ☐ Functional (específicas partes plan)
- ☐ Full-scale (simulación completa con herramientas)
- ☐ Ingeniería de caos (inyectar fallos reales en test)

7.5 Post-Mortem y Lecciones Aprendidas

Pregunta: ¿Existe un proceso post-incidente de análisis de lecciones aprendidas?

Escala de Madurez:

- ☐ (1) No existe: Sin análisis post-incidente formal
- ☐ (2) Iniciado: Reuniones ocasionales; documentación incompleta
- ☐ (3) Parcial: Post-mortem documentadas para >50% incidentes críticos; registro incompleto
- ☐ (4) Implementado: Post-mortem completadas <48h para incidentes críticos; lecciones tracking; implementation
- ☐ (5) Optimizado: Post-mortem sistemático todo incidente; seguimiento lecciones a nivel gobernanza; métricas recurrencia

CONTROL DE ACCESO E IDENTIDAD (SECCIÓN VIII)

MFA, IAM, least privilege, auditoría acceso privilegiado

8.1 Autenticación Multifactor (MFA)

Pregunta: ¿Está implementada la autenticación multifactor (MFA) en sistemas críticos?

Escala de Madurez:

- ☐ (1) No existe: Sin MFA
- ☐ (2) Iniciado: MFA solo en acceso remoto VPN
- ☐ (3) Parcial: MFA en >50% accesos críticos; algunos sistemas excluidos
- ☐ (4) Implementado: MFA en >90% accesos críticos (AD, cloud, apps); SMS/TOTP/U2F
- ☐ (5) Optimizado: MFA 100% accesos; passwordless autenticación (FIDO2, Windows Hello)

Pregunta complementaria: ¿Qué factores utiliza en MFA?

- ☐ SMS (texto)
- ☐ TOTP/App (Google Authenticator, Duo)
- ☐ U2F/FIDO2 (hardware token, biometría)
- ☐ Push notification
- ☐ Biometría (huella, facial)

8.2 Gestión de Identidades y Acceso (IAM)

Pregunta: ¿Existe una solución centralizada de gestión identidades (IAM - Identity and Access Management)?

Escala de Madurez:

- ☐ (1) No existe: Sin IAM; gestión manual por departamentos
- ☐ (2) Iniciado: Directorio centralizado (AD) pero sin provisioning automático
- ☐ (3) Parcial: IAM existe; provisioning/deprovision parcialmente automatizado; cobertura <75%
- ☐ (4) Implementado: IAM completo; provisioning automático; auditoría acceso; single sign-on (SSO)
- ☐ (5) Optimizado: IAM avanzado; provisioning automático basado roles; continuous authorization; integración risk scoring

8.3 Principio Least Privilege

Pregunta: ¿Se aplica el principio de "least privilege" (acceso mínimo necesario)?

Escala de Madurez:

- ☐ (1) No existe: Sin aplicación formal; acceso generoso
- ☐ (2) Iniciado: Conciencia; algunos roles definidos pero aplicación inconsistente
- ☐ (3) Parcial: Roles basados definidos; aplicado >50% usuarios; documentación incompleta
- ☐ (4) Implementado: RBAC completo; aplicado >85% usuarios; revisión acceso anual; auditoría
- ☐ (5) Optimizado: Just-In-Time (JIT) provisioning; revisión continua; atributos riesgos; automatización revocación

8.4 Gestión Acceso Privilegiado (PAM)

Pregunta: ¿Existe una solución de Privileged Access Management (PAM)?

Escala de Madurez:

- ☐ (1) No existe: Sin PAM; cuentas privilegiadas sin control centralizado
- ☐ (2) Iniciado: PAM piloto; cobertura <30% cuentas privilegiadas
- ☐ (3) Parcial: PAM activo; cobertura 30-70% cuentas privilegiadas; recording sesiones manual
- ☐ (4) Implementado: PAM completo; cobertura >85% cuentas privilegiadas; recording automático; auditoría
- ☐ (5) Optimizado: PAM empresarial; 100% cuentas privilegiadas; microprovisioning; MFA; integración SIEM

Pregunta complementaria: ¿Se auditaron los accesos privilegiados en el último año?

- ☐ No
- ☐ Sí, pero de forma manual/incompleta
- ☐ Sí, auditoría completa <12 meses
- ☐ Sí, auditoría continua

8.5 Revocación Acceso Post-Salida

Pregunta: ¿Existe un proceso formalizado de revocación de acceso cuando empleados salen?

Escala de Madurez:

- ☐ (1) No existe: Sin proceso; riesgo residuales altos
- ☐ (2) Iniciado: Proceso manual ad-hoc; tiempos variables
- ☐ (3) Parcial: Proceso documentado; revocación <24h; cobertura <75% sistemas
- ☐ (4) Implementado: Proceso automático; revocación <2h; cobertura >90% sistemas
- ☐ (5) Optimizado: Revocación automática inmediata; integración HRIS; auditoría acceso residual; monitoreo post-salida

VULNERABILIDADES EN SISTEMAS DE IA: ATLAS ESPECÍFICO (SECCIÓN IX)

Mitigation MITRE ATLAS, defensas LLM, agentes autónomos

9.1 Prompt Injection (AML.T0051)

Pregunta: ¿Ha evaluado su organización la vulnerabilidad a ataques de prompt injection?

Escala de Madurez:

- ☐ (1) No existe: Sin evaluación
- ☐ (2) Iniciado: Conciencia; testing manual incompleto
- ☐ (3) Parcial: Testing realizado; vulnerabilidades identificadas pero parcialmente mitigadas
- ☐ (4) Implementado: Testing regular (trimestral); mitigaciones implemented (input validation, prompt hardening)
- ☐ (5) Optimizado: Testing continuo; mitigaciones multi-capa (input + output filtering + ensemble); integrado SIEM

Pregunta complementaria: ¿Qué defensas ha implementado contra prompt injection?

- ☐ Ninguna / Sin evaluación
- ☐ Input validation/sanitización
- ☐ Separación system prompt vs. usuario input
- ☐ Output filtering (detection PII, API keys)
- ☐ Plugin sandboxing
- ☐ Ensemble de modelos con votación
- ☐ Monitoring comportamiento modelo vs. baseline

9.2 Data Poisoning (AML.T0020)

Pregunta: ¿Ha evaluado riesgos de envenenamiento de datos de entrenamiento?

Escala de Madurez:

- ☐ (1) No existe: Sin evaluación cadena datos
- ☐ (2) Iniciado: Conciencia; documentación datos origen incompleta
- ☐ (3) Parcial: Provenance datos identificada; vetting parcial proveedores
- ☐ (4) Implementado: Auditoría completa cadena suministro datos; vetting formalizados proveedores; datos sanitizados pre-training
- ☐ (5) Optimizado: Data provenance blockchain-like; testing adversarial training; rotación datos; continuous monitoring modelo comportamiento post-deploy

Pregunta complementaria: ¿Se realiza sanitización de datos antes de entrenar modelos?

- ☐ No
- ☐ Básica (remover duplicados)
- ☐ Estadística (outlier detection)
- ☐ Avanzada (semantic analysis, adversarial examples injection)

9.3 Model Extraction (AML.T0044)

Pregunta: ¿Ha implementado defensas contra robo de modelos (model extraction vía API queries)?

Escala de Madurez:

- ☐ (1) No existe: Sin defensas
- ☐ (2) Iniciado: Rate limiting básico en APIs; sin confidential prediction masking
- ☐ (3) Parcial: Rate limiting + prediction uncertainty (confidence intervals); cobertura <75% APIs
- ☐ (4) Implementado: Rate limiting, masking, differential privacy; cobertura >90% APIs; integración SIEM
- ☐ (5) Optimizado: Query filtering avanzado; prediction perturbation; integración ML security; anomaly detection queries

9.4 LLM Jailbreak (AML.T0054)

Pregunta: ¿Ha evaluado la resistencia de sus LLMs a intentos de jailbreak?

Escala de Madurez:

- ☐ (1) No existe: Sin testing jailbreak
- ☐ (2) Iniciado: Testing manual básico; conocimiento limitado técnicas jailbreak
- ☐ (3) Parcial: Testing regular con técnicas comunes (DAN, role-play); mitigaciones parciales
- ☐ (4) Implementado: Testing trimestral con payload avanzados; sistema prompts hardened; auditoría respuesta modelo
- ☐ (5) Optimizado: Testing continuo; adversarial training; cascading safety mechanisms; integrado evaluación seguridad

9.5 Model Provenance y Vetting

Pregunta: ¿Existe un proceso formalizado de vetting de modelos IA terceros?

Escala de Madurez:

- ☐ (1) No existe: Sin vetting; modelos usados sin evaluación
- ☐ (2) Iniciado: Evaluación manual ad-hoc; sin checklist formalizado
- ☐ (3) Parcial: Checklist vetting existe; cobertura ~50% nuevos modelos; documentación incompleta
- ☐ (4) Implementado: Vetting formalizado; scanning vulnerabilidades; testing robustness; auditoría anual
- ☐ (5) Optimizado: Vetting exhaustivo con SBOM (Software Bill of Materials); scanning backdoors; data provenance; continuous scanning post-deployment

9.6 Governance Agentes Autónomos

Pregunta: ¿Existe gobernanza específica para agentes IA autónomos en operación?

Escala de Madurez:

- ☐ (1) No existe: Sin governance; desconocimiento agentes operacionales
- ☐ (2) Iniciado: Inventario agentes iniciado; gobernanza ad-hoc
- ☐ (3) Parcial: Inventario agentes >50%; políticas parciales; control acceso herramientas limitado
- ☐ (4) Implementado: Inventario completo agentes; políticas documentadas; control acceso herramientas por agente; auditoría regular
- ☐ (5) Optimizado: Gobernanza integral; trazabilidad decisiones agente; sandbox aislamiento; multi-step authorization; incident response agentes

Pregunta complementaria: ¿Se ha documentado el acceso a herramientas/APIs por agente?

- ☐ No
- ☐ Parcialmente
- ☐ Sí, pero sin aplicación técnica (manual)
- ☐ Sí, con enforcement técnico (least privilege, sandboxing)

9.7 Testing Adversarial

Pregunta: ¿Realiza testing adversarial/red team específicamente contra sistemas IA?

Escala de Madurez:

- ☐ (1) No existe: Sin testing adversarial IA
- ☐ (2) Iniciado: Testing manual incompleto; técnicas limitadas
- ☐ (3) Parcial: Testing regular (anual); cobertura ~50% escenarios ATLAS
- ☐ (4) Implementado: Testing semestral; >70% escenarios ATLAS; herramientas adversarial (RobustML, Checklist)
- ☐ (5) Optimizado: Testing continuo; 100% escenarios ATLAS; ingeniería caos; integrado SIEM; métricas robustness tracked

CADENA DE SUMINISTRO (SECCIÓN X)

Evaluación proveedores, requisitos contractuales, monitoreo

10.1 Evaluación Seguridad Proveedores

Pregunta: ¿Se evalúan formalmente los requisitos de seguridad con proveedores TI/cloud/IA?

Escala de Madurez:

- ☐ (1) No existe: Sin evaluación formalizada; selección por precio/features
- ☐ (2) Iniciado: Evaluación manual básica; sin checklist
- ☐ (3) Parcial: Checklist evaluación existe; cobertura ~50% proveedores; criterios incompletos
- ☐ (4) Implementado: Evaluación formalizada; scoring seguridad; auditoría técnica; cobertura >80% proveedores
- ☐ (5) Optimizado: Evaluación exhaustiva con terceros; SOC2 Type II, ISO 27001 requeridos; continuous assessment post-contratación

10.2 Requisitos Contractuales Seguridad

Pregunta: ¿Se incluyen requisitos explícitos de seguridad en contratos con proveedores?

Escala de Madurez:

- ☐ (1) No existe: Sin cláusulas seguridad; lenguaje estándar
- ☐ (2) Iniciado: Cláusulas seguridad genéricas; sin enforcement
- ☐ (3) Parcial: Cláusulas seguridad específicas; cobertura <50% proveedores; sin SLA ciberseguridad
- ☐ (4) Implementado: Cláusulas extensas; SLA ciberseguridad definidos; derecho auditoría; requisitos incident notification
- ☐ (5) Optimizado: Contratos modulares seguridad; cláusulas adaptan al riesgo proveedor; integración gobernanza datos; warranty seguridad

10.3 Vetting Modelos/Datasets Terceros

Pregunta: ¿Se validan modelos IA y datasets de terceros antes de usar?

Escala de Madurez:

- ☐ (1) No existe: Sin vetting; uso directo modelos/datos
- ☐ (2) Iniciado: Evaluación manual básica; sin documentación
- ☐ (3) Parcial: Vetting documentado; cobertura ~50%; scanning vulnerabilidades incompleto
- ☐ (4) Implementado: Vetting completo con checklist; scanning de backdoors (Trojan models, poisoned data); provenance auditado
- ☐ (5) Optimizado: Vetting exhaustivo; SBOM verificado; testing adversarial; data lineage completa; continuous scanning post-deployment

10.4 Monitoreo Vendedores Post-Contratación

Pregunta: ¿Se monitorean continuamente los vendedores/proveedores post-contratación?

Escala de Madurez:

- ☐ (1) No existe: Sin monitoreo post-contratación
- ☐ (2) Iniciado: Monitoreo manual ocasional; basado en incidentes solo
- ☐ (3) Parcial: Auditoría anual; SLA monitoreados; response incidentes documentada
- ☐ (4) Implementado: Auditoría semestral; KPI seguridad tracked; integración SIEM alertas proveedor; escalation process
- ☐ (5) Optimizado: Monitoreo continuo; real-time dashboard proveedores; integración inteligencia amenazas; risk scoring dinámico

10.5 Gestión Incidentes Proveedores

Pregunta: ¿Existe un proceso formalizado para detectar y responder a incidentes de proveedores?

Escala de Madurez:

- ☐ (1) No existe: Sin proceso
- ☐ (2) Iniciado: Notification channel existe; sin SLA
- ☐ (3) Parcial: Proceso documentado; SLA parcial; response <48h para críticos
- ☐ (4) Implementado: SLA claro; notification <2h; impacto assessment; remediation tracking
- ☐ (5) Optimizado: Proceso automatizado; integración SIEM alertas proveedor; impact analysis automático; escalation cadena comando

CUMPLIMIENTO REGULATORIO Y GOBERNANZA IA (SECCIÓN XI)

AI Act, NIS2, RGPD, AIDA, auditorías

11.1 AI Act (EU 2024/1689)

Pregunta: ¿Ha evaluado conformidad con AI Act europeo (vigente desde 2 agosto 2025)?

Escala de Madurez:

- ☐ (1) No existe: Sin evaluación
- ☐ (2) Iniciado: Conciencia; assessment iniciada; no completada
- ☐ (3) Parcial: Assessment completado; alto-riesgo identificados; mitigaciones parciales
- ☐ (4) Implementado: Assessment completo; clasificación riesgos; documentación conformidad; governance AESIA
- ☐ (5) Optimizado: Conformidad total; continuous compliance monitoring; auditorías externas aprobadas; sandbox regulatorio AESIA

Pregunta complementaria: ¿Tiene sistemas IA clasificados como "alto riesgo" bajo AI Act?

- ☐ No
- ☐ Sí, pero <3 sistemas
- ☐ Sí, 3-10 sistemas
- ☐ Sí, >10 sistemas
- ☐ Desconocido

11.2 NIS2 (Directiva Ciberseguridad)

Pregunta: ¿Se ha evaluado conformidad con NIS2?

Escala de Madurez:

- ☐ (1) No existe: Sin evaluación
- ☐ (2) Iniciado: Categorización scope iniciada; aún en análisis
- ☐ (3) Parcial: Scope identificado; medidas parcialmente implementadas; <75% controles NIST
- ☐ (4) Implementado: Scope claro; >90% controles NIST implementados; auditoría realizada
- ☐ (5) Optimizado: Conformidad completa; continuous compliance; auditoría externa anual; integrated governance con CCN

Pregunta complementaria: ¿Su organización es operador esencial/importante bajo NIS2?

- ☐ No aplica
- ☐ Probablemente no (PYME pequeña)
- ☐ Posiblemente (tamaño medio, sector crítico)
- ☐ Sí, definitivamente operador esencial
- ☐ Sí, definitivamente operador importante

11.3 RGPD y Protección Datos Personales

Pregunta: ¿Ha completado evaluación de conformidad RGPD?

Escala de Madurez:

- ☐ (1) No existe: Sin evaluación
- ☐ (2) Iniciado: Assessment iniciada; gaps identificados
- ☐ (3) Parcial: Medidas parcialmente implementadas; EIPD completadas; <75% requerimientos
- ☐ (4) Implementado: EIPD completadas; >90% requerimientos; DPO designado; auditoría anual
- ☐ (5) Optimizado: Privacy-by-design; automatización completa; integración gobernanza; auditoría continua

11.4 AIDA (Ley Buen Uso IA España)

Pregunta: ¿Conoce y ha evaluado AIDA (Ley Buen Uso IA aprobada marzo 2025)?

Escala de Madurez:

- ☐ (1) No existe: Sin conocimiento / evaluación
- ☐ (2) Iniciado: Conciencia; evaluación incompleta
- ☐ (3) Parcial: Assessment realizado; ciertas medidas implementadas
- ☐ (4) Implementado: Conformidad documentada; alineado AESIA; medidas específicas españolas
- ☐ (5) Optimizado: Conformidad total; participación eventualmente en sandboxes AESIA; auditoría externa

11.5 Auditorías Externas

Pregunta: ¿Realiza auditorías externas de seguridad/ciberseguridad?

Escala de Madurez:

- ☐ (1) No existe: Sin auditorías externas
- ☐ (2) Iniciado: Auditoría ocasional ad-hoc
- ☐ (3) Parcial: Auditoría anual; scope limitado
- ☐ (4) Implementado: Auditoría anual formales; múltiples estándares (ISO 27001, PCI-DSS, SOC2)
- ☐ (5) Optimizado: Auditorías múltiples anuales; evaluadores independientes; integración resultados gobernanza

Pregunta complementaria: ¿Está certificada su organización en algún estándar seguridad?

- ☐ No
- ☐ Sí, ISO 27001
- ☐ Sí, SOC2 (Type I o II)
- ☐ Sí, PCI-DSS
- ☐ Sí, múltiples (especifique): ____

11.6 Reporte Incidentes Brechas

Pregunta: ¿Existe proceso para detectar y reportar brechas datos a autoridades?

Escala de Madurez:

- ☐ (1) No existe: Sin proceso formal
- ☐ (2) Iniciado: Conciencia; sin SLA de report
- ☐ (3) Parcial: Proceso documentado; SLA no siempre cumplido
- ☐ (4) Implementado: Proceso formalizado; report <72h autoridades; afectados notificados
- ☐ (5) Optimizado: Detección automática breaches; integración SIEM; reporting automático autoridades; análisis impacto

CAPACITACIÓN Y CONCIENCIA EMPLEADOS (SECCIÓN XII)

Formación seguridad, simulaciones phishing, métricas efectividad

12.1 Programa Conciencia Seguridad

Pregunta: ¿Existe un programa formal de conciencia en ciberseguridad?

Escala de Madurez:

- ☐ (1) No existe: Sin programa
- ☐ (2) Iniciado: Training ad-hoc; cobertura <25% empleados
- ☐ (3) Parcial: Training anual obligatorio; cobertura 25-75%; materiales básicos
- ☐ (4) Implementado: Training anual + trimestral; cobertura >75%; módulos especializados por rol
- ☐ (5) Optimizado: Training continuo gamificado; 100% cobertura; personalizado por riesgos individuales; métricas comportamiento

12.2 Cobertura Capacitación

Pregunta: ¿Qué porcentaje de empleados completó training seguridad en últimos 12 meses?

- ☐ < 10%
- ☐ 10-25%
- ☐ 26-50%
- ☐ 51-75%
- ☐ 76-90%
- ☐ >90%

Pregunta complementaria: ¿Se realiza evaluación post-training?

- ☐ No
- ☐ Cuestionario básico
- ☐ Evaluación formal con score
- ☐ Evaluación + remediación para bajo score

12.3 Simulaciones Phishing

Pregunta: ¿Realiza simulaciones de ataques phishing?

Escala de Madurez:

- ☐ (1) No existe: Sin simulaciones
- ☐ (2) Iniciado: Simulación ad-hoc anual; cobertura <25%
- ☐ (3) Parcial: Simulación trimestral; cobertura 25-75%; análisis resultados
- ☐ (4) Implementado: Simulación mensual; cobertura >75%; correlación con training; escalation para alto-riesgo
- ☐ (5) Optimizado: Simulación continua adaptativa; 100% cobertura; payload realista ATT&CK-aligned; integración SIEM comportamiento usuario

12.4 Métricas Phishing: Tasas de Clics

Pregunta: ¿Cuál es la tasa de clics promedio en emails phishing simulado?

- ☐ > 40% (crítico: vulnerabilidad alta)
- ☐ 30-40% (alto riesgo)
- ☐ 20-30% (medio)
- ☐ 10-20% (bajo)
- ☐ < 10% (muy bajo, bien entrenados)
- ☐ No se mide

Pregunta complementaria: ¿Ha mejorado esta tasa en últimos 12 meses?

- ☐ Peor (aumentada)
- ☐ Igual
- ☐ Mejorada <20% reducción
- ☐ Significativamente mejorada (20-50% reducción)
- ☐ Muy mejorada (>50% reducción)

12.5 Tiempo Respuesta Phishing

Pregunta: ¿Cuál es el tiempo promedio para que empleados reporten phishing simulado?

- ☐ > 30 minutos (tardío)
- ☐ 15-30 minutos
- ☐ 5-15 minutos
- ☐ <5 minutos (excelente)
- ☐ No se mide

12.6 Training por Roles Específicos

Pregunta: ¿Se proporciona training especializado según rol/responsabilidad?

Escala de Madurez:

- ☐ (1) No existe: Training genérico igual para todos
- ☐ (2) Iniciado: Algunos roles reciben training adicional
- ☐ (3) Parcial: Developers, admins, CISO reciben training específico pero incompleto
- ☐ (4) Implementado: Roles críticos (developers, admins, data managers) training especializado anual
- ☐ (5) Optimizado: Training granular por responsabilidad + risk profile continuo; gamification; certificaciones

12.7 Presupuesto Capacitación

Pregunta: ¿Cuál es el presupuesto anual aproximado para capacitación seguridad?

- ☐ < 1.000 €
- ☐ 1.000 - 10.000 €
- ☐ 10.001 - 50.000 €
- ☐ 50.001 - 250.000 €
- ☐ > 250.000 €
- ☐ No cuantificado

CONTINUIDAD Y RESILIENCIA (SECCIÓN XIII)

BCP, DRP, redundancia, seguros

13.1 Plan Continuidad Negocio (BCP)

Pregunta: ¿Existe un Plan de Continuidad de Negocio (BCP) documentado, con RTO/RPO?

Escala de Madurez:

- ☐ (1) No existe: Sin BCP formal
- ☐ (2) Iniciado: Documento borrador; sistemas críticos sin identificar
- ☐ (3) Parcial: BCP existe; cobertura ~50%; RTO/RPO parcialmente definidos
- ☐ (4) Implementado: BCP completo; RTO/RPO definidos para críticos; actualizado anualmente
- ☐ (5) Optimizado: BCP integral; RTO <4h, RPO <1h críticos; simulacros regulares; integración gobernanza

13.2 Plan Disaster Recovery (DRP)

Pregunta: ¿Existe un Plan de Disaster Recovery específico con procedimientos técnicos?

Escala de Madurez:

- ☐ (1) No existe: Sin DRP formal
- ☐ (2) Iniciado: DRP borrador; procedimientos incompletos
- ☐ (3) Parcial: DRP existe; cobertura ~50% sistemas; procesos parcialmente validados
- ☐ (4) Implementado: DRP completo; procedimientos probados; runbooks; integración con BCP
- ☐ (5) Optimizado: DRP sofisticado; automatización failover; DR site activo; test mensual

13.3 Pruebas Failover y Recuperación

Pregunta: ¿Con qué frecuencia realiza pruebas de recuperación (failover, restauración)?

Escala de Madurez:

- ☐ (1) Nunca: Sin pruebas formales
- ☐ (2) Ad-hoc: Pruebas incompletas, irregulares
- ☐ (3) Anual: Una prueba por año; documentación incompleta
- ☐ (4) Semestral: Pruebas 2x/año; documentadas; gaps identificados
- ☐ (5) Trimestral o superior: Pruebas regulares; métricas RTO/RPO validadas; resultados integrados gobernanza

13.4 Redundancia Infraestructura

Pregunta: ¿Qué nivel de redundancia existe en infraestructura crítica?

- ☐ N (single punto fallo)
- ☐ N+1 (failover a 1 alternativa)
- ☐ N+2 (dos redundancias)
- ☐ Multi-site activo-activo
- ☐ Geo-redundancia (múltiples regiones/datacenters)

13.5 Seguros Ciberseguridad

Pregunta: ¿Tiene póliza de seguros cibernético activa?

Escala de Madurez:

- ☐ (1) No existe: Sin cobertura
- ☐ (2) Iniciado: Póliza básica; cobertura limitada (<1M€)
- ☐ (3) Parcial: Póliza estándar; cobertura 1-5M€; gaps documentados
- ☐ (4) Implementado: Póliza completa; cobertura >5M€; revisión anual
- ☐ (5) Optimizado: Póliza personalizada; crisis management incluido; auditoría anual; integración governance riesgos

SECCIÓN DE REFLEXIÓN FINAL (OPCIONAL)

F.1 Autodiagnóstico General

Pregunta: En escala 1-5, ¿cómo calificaría la postura general de ciberseguridad de su organización?

- ☐ (1) Muy débil (requerida acción urgente)
- ☐ (2) Débil (importantes gaps)
- ☐ (3) Moderada (cumple básico, mejoras necesarias)
- ☐ (4) Fuerte (programa maduro, mejoras continuas)
- ☐ (5) Muy fuerte (liderazgo en seguridad, innovación)

F.2 Prioridades Mejora

Pregunta: ¿Cuáles son sus 3 principales prioridades de mejora en ciberseguridad para 2026?

3.

4.

5.

F.3 Barreras Principales

Pregunta: ¿Cuáles son las principales barreras para mejorar ciberseguridad?

- ☐ Presupuesto insuficiente
- ☐ Falta de talento/expertise
- ☐ Resistencia del negocio / prioridad baja
- ☐ Complejidad técnica / legacy systems
- ☐ Regulación unclear
- ☐ Otras (especifique): ____

F.4 Observaciones Adicionales

Espacio para comentarios adicionales:

CIERRE Y AGRADECIMIENTO

Agradecemos sinceramente su tiempo y colaboración en esta encuesta. Sus respuestas contribuirán a crear un retrato diagnóstico **riguroso, ético y propositivo** del estado de ciberseguridad en organizaciones españolas en era de sistemas IA.

Los resultados serán compilados en **informe sectorial anonimizado** que servirá como referencia benchmark y guía de mejora para el ecosistema.

Próximos pasos:

1. Análisis respuestas (enero-febrero 2026)
2. Generación informe benchmark (marzo 2026)

3. Sesiones feedback participantes (abril 2026)

4. Publicación hallazgos clave (mayo 2026)

Para preguntas: contacto@encuestaciberseguridad-ia.es

Encuesta diseñada por: Consorcio Científico de Datos y Estrategas Ciberseguridad España

Versión: 1.0

Fecha: Enero 2026

Confidencialidad: ISO 27001 / RGPD certified handling